Sofacy Fysbis Backdoor Investigation - Student Briefing

1. Malware Overview

- Family / type: Sofacy (Fysbis)
- Aliases: Not specified in this scenario
- Behaviour class: Backdoor

Fysbis is a modular Linux trojan/backdoor that implements plug-in and controller modules as distinct classes. It can install itself to a victim system with or without root privileges. It includes both 32-bit and 64-bit versions of ELF binaries. The malware has capabilities for remote shell control, lateral movement, and persistence.

Associated MITRE ATT&CK techniques:
- Persistence: Systemd Service
- Lateral Movement: SSH
- Command and Control: Non-Standard Port

Associated CVEs: Not specified in this scenario

2. Exercise Objective

The learning goal of this cyber-range exercise is to investigate and respond to a potential compromise involving the Sofacy Fysbis backdoor trojan. This scenario is designed for an Intermediate difficulty level, with a Defence-oriented cybersecurity approach, aligning with the Incident Response NICE work role.

By the end of this exercise, a successful trainee will have demonstrated the ability to identify suspicious services, determine persistence mechanisms, and locate malicious artifacts on a compromised Linux system.

3. Sandbox Topology & Malware Emulation

The sandbox topology consists of the following hosts and networks:

```
server-switch (192.168.40.0/24)
    |
    |-- c2-server (192.168.40.5)
target-switch (192.168.50.0/24)
    |
    |-- target (192.168.50.5)
    |
    |-- next-target (192.168.50.6)
```

Hosts:
- c2-server: Emulates the command and control server.
- target: The compromised system running the Fysbis backdoor.
- next-target: A potential lateral movement target.

Malware Emulation:
- The malware behaviour is emulated by the dbus-notifier.service and dbus-notifier.timer systemd service and timer on the target host.
- The malicious artifact is emulated by the file /home/cyrano/dbus-inotifier on the target host.
- The C2 communication is emulated by the lab-checkin.timer and lab-checkin.service systemd timer and service on the c2-server host, which periodically connects to the target host on port 80.

4. Student Tasks

ACCESS step:

- Use the following credentials to enter the training levels:
- Username: cyrano
- Password: cyrano
- Passkey: start

TRAINING_LEVEL 1:
- Task: Identify and investigate an unauthorized or suspicious service running on the target system.
- Objective: Enumerate running services and distinguish legitimate from suspicious services.
- TYPE of artifact/flag expected: Service name

TRAINING_LEVEL 2:
- Task: Determine how the suspicious service is automatically started after reboot.
- Objective: Identify persistence mechanisms (e.g., systemd, cron, scheduled task).
- TYPE of artifact/flag expected: Timer name

TRAINING_LEVEL 3:
- Task: Locate the executable or file associated with the suspicious activity.
- Objective: Correlate processes with files on disk and identify malicious artifacts.
- TYPE of artifact/flag expected: File path

5. Solution Walkthrough & Flags

TRAINING_LEVEL 1:
- Methodology:
  1. SSH into the target host using the provided credentials.
  2. List all running services using the command:
     ```
     systemctl list-units --type=service
     ```
  3. Identify the suspicious service named dbus-notifier.service.
- Flag: dbus-notifier.service

TRAINING_LEVEL 2:
- Methodology:
  1. On the target host, list all active timers using the command:
     ```
     systemctl list-timers
     ```
  2. Identify the timer associated with the suspicious service, named dbus-notifier.timer.
- Flag: dbus-notifier.timer

TRAINING_LEVEL 3:
- Methodology:
  1. On the target host, list all files in the home directory of the user cyrano using the command:
     ```
     ls -la /home/cyrano/
     ```
  2. Identify the malicious artifact associated with the suspicious activity, located at /home/cyrano/dbus-inotifier.
- Flag: /home/cyrano/dbus-inotifier

6. Knowledge Gained

- Usage of systemctl to enumerate and investigate running services and timers.
- Identification of persistence mechanisms using systemd services and timers.
- Investigation of file systems to locate and identify malicious artifacts.
- Mapping of real-world malware behaviours to emulated sandbox artifacts.
- Practical application of Incident Response techniques in a Linux environment.